

OPERATION IRON RAVEN

Student Name: HABEEBAH ADEYINKA OLUGBOGI

Registration Number: c11.ehit2617337@icdfa.edu.ng

Cohort Program: ETHICAL HACKER INTERNSHIP

Course: CIP-A105: Offensive Security

Instructor:

Submission Date: 16/9/2026

EXECUTIVE SUMMARY

This report covers a penetration test against OPFOR-01 (Raven). The host was 192.168.44.129. Our goal was to find weaknesses, try to use them, and record what worked. During recon, I saw a Debian system running Apache. It also had WordPress 4.8.7. An OpenSSH service was reachable as well. I then mapped the exposed parts of the target. I noted services for HTTP and SSH. I also saw rpcbind responding. On the WordPress site, I found a blog and confirmed two user accounts: michael and steven.

The work moved through Phases 0 to 3 without major issues. These steps covered reconnaissance, attack-surface listing, and vulnerability review. For Phase 4, Initial Access, I tried more than one approach. I tried:

- PHPMailer argument injection (CVE-2016-10033) against /contact.php
- Metasploit phpmailer_arg_injection module
- Manual sendmail argument injection with \${IFS} and tab separators
- XML-RPC password brute-forcing against WordPress users even though I know I were asked not to bruteforce but I was too frustrated.

The backdoor files were placed in the web root using the sendmail -X method. Still, the reverse shell did not connect during the time I had for the engagement. I think the main issues were these. First, contact.php turned out to be a plain HTML page, not a script that handles mail. Second, the log file meant to hold the -X data may never have reached disk. That is likely because sendmail stopped earlier during recipient checks, before it processed the message.

Result: I did not gain initial access. This write-up covers what I did, what I saw, and what to fix next if I run another attempt.

Scope and Rules of Engagement

In Scope

- Target Address Services
- OPFOR-01 (Raven) 192.168.44.129 TCP/22 (SSH), TCP/80 (HTTP), TCP/111 (rpcbind), TCP/43212 (RPC status)

Out of Scope

- Any host outside 192.168.44.0/24
- Denial-of-service attacks
- Destructive actions on the target
- Any activity outside the defined CTF window

Rules of Engagement

- Non-destructive exploitation only
- Evidence captured for every action
- Operator activity log maintained
- Target restored to clean snapshot after engagement
- No lateral movement outside the assigned target

Operator

Kali Linux attacker VM at 192.168.44.128

Laboratory Architecture and Methodology

Architecture

Role	Host	Address
Attacker	Kali Linux	192.168.44.128
Target	Raven (Debian)	192.168.44.129

Methodology

The engagement followed a structured phase model:

Phase	Activity	Status
0	Preparation and control	Complete
1	Reconnaissance	Complete
2	Attack-surface enumeration	Complete
3	Vulnerability analysis	Complete
4	Initial access	Attempted – not achieved
5	Post-exploitation	Not reached
6	Objective collection	Not reached
7	Withdrawal and restoration	Partial

Tools used: nmap, curl, gobuster, wpscan, nc, Metasploit, custom Python scripts.

Attack-Surface Summary

Open Ports and Services

Port	Service	Version
22/tcp	SSH	OpenSSH 6.7p1 Debian 5+deb8u4
80/tcp	HTTP	Apache httpd 2.4.10 (Debian)
111/tcp	rpcbind	rpcbind 2-4 (RPC #100000)
43212/tcp	RPC status	status 1 (RPC #100024)

```
(habeebah@kali)-[~]
$ ip neigh
192.168.44.254 dev eth1 lladdr 00:50:56:ff:2d:e9 STALE

(habeebah@kali)-[~]
$ nmap -sn 192.168.44.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-12 13:54 WAT
Nmap scan report for 192.168.44.1
Host is up (0.0034s latency).
MAC Address: 00:50:56:C0:00:01 (VMware)
Nmap scan report for 192.168.44.129
Host is up (0.00086s latency).
MAC Address: 00:0C:29:1F:75:9C (VMware)
Nmap scan report for 192.168.44.254
Host is up (0.0019s latency).
MAC Address: 00:50:56:FF:2D:E9 (VMware)
Nmap scan report for 192.168.44.128
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 28.03 seconds

(habeebah@kali)-[~]
$
```

Web Technologies

Component	Detail
CMS	WordPress 4.8.7
Web server	Apache 2.4.10 (Debian)
PHP endpoint	/contact.php
REST API	/wordpress/wp-json/ (accessible)
XML-RPC	/wordpress/xmlrpc.php (enabled)
Uploads directory	Listing enabled (/wordpress/wp-content/uploads/)

Enumerated Users

michael (confirmed via author ID brute forcing)
steven (confirmed via author ID brute forcing)

```
habeebah@kali: ~/CIP-A105_c1Lehr2617337_CTF1_Iron-Raven
File Actions Edit View Help
[+] The external WP-Cron seems to be enabled: http://192.168.44.129/wordpress/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299
[+] WordPress version 4.8.7 identified (Insecure, released on 2018-07-05).
| Found By: Emoji Settings (Passive Detection)
| - http://192.168.44.129/wordpress/, Match: 'wp-includes/js/wp-emoji-release.min.js?ver=4.8.7'
| Confirmed By: Meta Generator (Passive Detection)
| - http://192.168.44.129/wordpress/, Match: 'WordPress 4.8.7'
[!] The main theme could not be detected.
[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:01 → (10 / 10) 100.00% Time: 00:00:01
[+] User(s) Identified:
[+] michael
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)
[+] steven
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)
[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
[+] Finished: Wed Sep 16 19:05:13 2026
[+] Requests Done: 51
[+] Cached Requests: 4
[+] Data Sent: 12.665 KB
[+] Data Received: 286.109 KB
[+] Memory used: 170.016 MB
[+] Elapsed time: 00:00:04
```

Confirmed Findings and Risk Ratings

	Finding	Risk	Evidence
F1	WordPress 4.8.7 (outdated)	High	Meta generator, emoji script
F2	XML-RPC enabled	Medium	Direct access to xmlrpc.php
F3	Uploads directory listing enabled	Medium	wp-content/uploads/ index
F4	WordPress user enumeration possible	Medium	REST API and author ID brute force
F5	SSH service exposed	Low	Version disclosure
F6	rpcbind exposed	Low	RPC enumeration
F7	PHPMailer 5.2.16 detected	Informational	X-Mailer header on /contact.php submissions

Initial-Access Narrative

The following vectors were attempted during Phase 4.

PHPMailer argument injection (CVE-2016-10033)

Why this looked real:

The /contact.php page showed an X-Mailer line with PHPMailer 5.2.17.

That header suggests the form mail code could be open to argument injection via the Sender value.

What we tried:

We sent several payload forms, such as:

anarcoder.py (40974.py)

A custom Python script that used tab separators

A custom Python script that used \${IFS}

A Metasploit module: exploit/multi/http/phpmailer_arg_injection

What happened:

A backdoor file did get written under /var/www/html/ on the target.

Even so, direct curl access to the backdoor gave 404 Not Found.

That looks like sendmail did not flush the log data to disk yet.

We also collected sendmail output using -X.

Those logs showed: 550 5.1.1 ... User unknown.

In practice, the recipient check failed before the log write occurred.

We tested for command injection on /contact.php.

We used email=test@test.com;id.

The request hung and returned no usable output.

This points to the endpoint not passing the email value into a shell.

7.2 WordPress XML-RPC brute force

Why we checked:

WordPress 4.8.7 with XML-RPC on can allow user probing using wp.getUsersBlogs.

What we did:

WPScan ran with two password lists.

We targeted the accounts michael and steven.

Attempts:

Custom list (examples include password, raven, R@v3n1backdoor, and more).

No hits came back.

We also started a run using rockyou.txt, but it did not finish during the time we had.

Outcome:

No working credentials were found.

7.3 Direct MySQL access

Step:

```
mysql -h 192.168.44.129 -u root -p
```

Output we got:

```
ERROR 2002 (HY000): Can't connect to server on '192.168.44.129' (115)
```

This matches the idea that MySQL only listens on localhost.

7.4 Root cause analysis

I believe these issues stopped the first access attempts:

/contact.php is a static HTML template page, not a mail-handling PHP script. The X-Mailer header observed in earlier output was a red herring — it originated from a different request path.

Sendmail rejects the injected recipient before the -X log is flushed, so the backdoor file is never written to disk.

Post exploitation and privilege escalation

Not completed. We did not get initial access. Because of that, we did not run any follow up checks or try to raise privileges.

These planned actions were not reached:

- Local user and group look up
- Check sudo settings
- Review cron jobs and scheduled tasks
- Scan for SUID and SGID binaries
- Search for possible credential files like wp-config.php and .bash_history
- Verify MySQL credentials using the WordPress config values

Mission Objectives and Proof of Completion

Objective	Status	Evidence
Find OPFOR-01 with no address provided	Done	nmap -sn scan results
Prove the host can be reached	Done	Ping plus neighbor checks
List exposed services	Done	nmap, wpscan, and gobuster results
Find WordPress accounts	Done	WPScan user listing
Get the first foothold	Failed	Several tries were logged
Grab required mission items	Missed	Nothing was collected
Reset the target back to normal hand	Partial	Loose backdoor files had to be removed by hand

Remediation

- Update WordPress to the newest stable version.
- If you do not need XML-RPC, turn it off.
- In Apache, stop directory listing for the uploads folder.
- Lock down rpcbind so it only listens on localhost.
- Use a strict password rule for WordPress logins.
- Add multi-factor authentication for the WordPress admin area.
- Add login throttling and lock accounts after repeated failed tries.
- For SSH, limit access by source IP. Also turn off SSH password logins.
- 10.3 Strategic
- Use a clear patch process, done on a schedule.
- Separate web-facing services from the internal network.

Conclusion and Lessons Learned

The work finished Phases 0 through 3. It also delivered a full view of the attack surface for OPFOR-01. Still, the team did not get in during the time box. Before you attack, confirm what the endpoint actually is. They treated /contact.php like a mail form. In reality, it is a plain static HTML page. That error cost a lot of time. Be careful with header data. Early output showed an X-Mailer: PHPMailer value. That did not prove it came from /contact.php. The sendmail argument injection also depends on the recipient check working. If the recipient is not valid, the -X log does not get written out. When that log stays in memory, the backdoor file never appears. WordPress user listing can be quick and quiet. Brute force is different. It needs a wordlist that matches the target. rockyou.txt should be fully used before you decide the attempt is a failure.

12. Appendices

12.1 Operator Activity Log (Extract) The full operator log is a txt file in this repo. Tho towards the end when I was troubleshooting why I couldn't gain initial access, I restarted my Kali and didn't remember to start it

Timestamp Action

2026-09-12 13:54	Network discovery scan (nmap -sn 192.168.44.0/24)
2026-09-12 14:20	First full port scan against 192.168.44.129
2026-09-12 14:28	Service version detection
2026-09-12 15:15	WordPress REST API enumeration
2026-09-13 14:18	First PHPMailer exploit attempt
2026-09-13 21:14	Metasploit phpmailer_arg_injection attempt
2026-09-14 12:33	SSH service enumeration
2026-09-16 19:05	WPScan user enumeration
2026-09-16 19:08	WPScan XML-RPC brute-force attempt

Supporting Evidence

All raw output files are in this repo

12.3 Cleanup Required

The following files were written to the target web root during testing and must be removed:

text

- /var/www/html/JonzbrGv.php
- /var/www/html/kveXdJQK.php
- /var/www/html/qsTPUbOB.php
- /var/www/html/vesVd5rI.php
- /var/www/html/r97Ur6uI.php
- /var/www/html/pfIYTUZd.php
- /var/www/html/32YMKKy1.php
- /var/www/html/r3.php
- /var/www/html/raven.php
- /var/www/html/raven_shell.php

References

CVE-2016-10033 – PHPMailer Remote Code Execution

WordPress 4.8.7 release notes

WPScan documentation – XML-RPC password attack

Kali Linux tool documentation: nmap, curl, wpscan, msfconsole